DuocUC | ESCUELA DE INFORMÁTICA Y TELECOMUNICACIONES

Sistema de exámenes médicos Cuidarte+

Informe de seguridad y calidad en el desarrollo de software

ISY1102 - Seguridad y calidad en el desarrollo de software
Sección 001V

Integrantes
Felipe Salazar

ÍNDICE

ÍNDICE 2
1. Introducción 3
2. Criterios de calidad 3
3. Plan de pruebas 4
3.1 Estrategia de pruebas 4
3.2 Tipos de prueba 4
3.3 Criterios de aceptación 5
3.4 Herramientas utilizadas 5
4. Diseño de casos de prueba 6

1. Introducción

El presente informe detalla el plan de pruebas para el sistema “Cuidate+”, una plataforma web orientada a centros de salud diseñada para la gestión de pacientes, exámenes médicos y documentos clínicos. El propósito de este plan de pruebas es asegurar que el software cumpla íntegramente con los requerimientos funcionales, de rendimiento y de seguridad definidos en la Especificación de Requerimientos de Software (ERS). Se busca asegurar especialmente la protección de la información médica sensible (mediante estándares como TLS y

cifrado) y garantizar una alta usabilidad para los usuarios objetivos, con especial atención a los adultos mayores.

El sistema Cuidate+ es una aplicación web multicapa que consta de un Frontend desarrollado en React, con un Backend basado en API RESTful con Node.js/Express y una base de datos PostgreSQL, Este informe se estructura definiendo primero los criterios de calidad esperados, luego la estrategia y tipos de prueba a ejecutar (funcionales, seguridad, usabilidad y rendimiento), para finalizar con el diseño específico de los casos de prueba

2. Criterios de calidad

Acorde a las especificaciones del proyecto Cuidate+, el software debe cumplir con los siguientes estándares:

- **Calidad de Usabilidad y Accesibilidad:** La interfaz (desarrollada en React) debe ser responsiva y contar con tipografía legible (tamaño mínimo de 12px). Se exige un contraste adecuado, controles de interfaz de tamaño suficiente para pantallas táctiles y el uso de etiquetas ARIA para navegación por teclado, asegurando accesibilidad para adultos mayores.
- **Calidad de Rendimiento y Confiabilidad:** Las operaciones de persistencia de datos (CRUD) simples, deben ejecutarse en menos de 300 milisegundos. La página principal debe cargar en menos de 2 segundos en una conexión móvil promedio, el sistema debe soportar una carga de al menos 200 usuarios concurrentes. La disponibilidad esperada del sistema es del 99.5%
- **Calidad de Seguridad:** Toda comunicación cliente-servidor debe estar cifrada con TLS las contraseñas deben estar encriptadas usando el algoritmo bcrypt y el acceso a la plataforma se debe manejar con token JWT de corta vigencia. se debe garantizar la protección contra vulnerabilidades como inyección SQL, XSS y CSRF.
- **Normativas y compatibilidad:** El sistema debe cumplir con normativas de protección de datos personales y ser compatible con las últimas 2 versiones de navegadores modernos (Chrome, Firefox, Safari, Edge).

3. Plan de pruebas

3.1 Estrategia de pruebas

- **Enfoque:** Se utilizará un enfoque mixto. Las pruebas de interfaz gráfica, flujos de navegación (como el registro y carga de documentos) y accesibilidad para adultos mayores se ejecutarán de manera manual. Las pruebas de la API REST (Backend en Express), rendimiento y seguridad de base de datos (PostgreSQL) estarán enfocadas en la automatización.

- **Etapas de proceso:** Se iniciará con pruebas unitarias en componentes de React, seguido de pruebas de integración en los endpoints del Backend, pruebas de usabilidad guiadas con usuarios finales, y finalmente pruebas de penetración y carga.
- **Priorización:** Tendrán prioridad crítica las pruebas relacionadas al control de acceso por roles (Administrador, Médico, Paciente), la seguridad de los documentos clínicos subidos y las funciones de auditoría .
- **Criterios de entrada y salida:** Las pruebas comenzarán cuando el entorno QA esté configurado con el stack React/Express/PostgreSQL. Se considerarán finalizadas (salida) cuando las pruebas de usabilidad con 5 usuarios mayores no presenten bloqueos y cuando la auditoría de seguridad se apruebe sin hallazgos críticos.

3.2 Tipos de prueba

- **Pruebas Funcionales:** Para verificar los flujos de creación, lecturas actualización y eliminación (CRUD) de usuarios, pacientes y exámenes médicos
- **Pruebas no Funcionales:**
    - **Pruebas de Seguridad:** Para auditar los tokens JWT, la encriptación bcrypt, el control de acceso a documentos y la resistencia contra inyecciones SQL/XSS.
- **Pruebas de Integridad:** Para verificar que las operaciones validen correctamente la información ingresada, que los documentos almacenados estén referenciados correctamente en la base de datos y que las eliminaciones soliciten confirmación al usuario
- **Pruebas de Usabilidad y Accesibilidad:** Para validar que la interfaz cuente con un tamaño de fuente mínimo de 12px, contraste suficiente, etiquetas ARIA para navegación por teclado y controles adecuados para pantallas táctiles.
- **Pruebas de Rendimiento:** Para ejecutar pruebas de carga que aseguren que el sistema soporta 200 usuarios concurrentes y responde dentro de los umbrales de tiempo exigido.

3.3 Criterios de aceptación

Para que los casos de prueba generales sean aprobados, el sistema Cuidate+ debe cumplir transversalmente lo siguiente:

- **Funcionales:** Operaciones CRUD debe ejecutarse sin errores con validaciones server-side implementadas y guardando los logs de auditoría ante acciones críticas.
- **No Funcionales(Seguridad y Rendimiento):** Auditoría de seguridad (Pentesting) superada sin hallazgos críticos y operaciones de carga/descarga de documentos finalizadas en un máximo de 10 segundos.

- **Reglas de Negocio:** El sistema debe restringir correctamente las operaciones según el rol (ej. un paciente solo debe tener permisos de lectura de su información).
- **Usabilidad y Accesibilidad:** Las pruebas de usabilidad con 5 usuarios mayores de edad representativos no muestran bloqueos mayores y cumplen con el cumplimiento básico de accesibilidad.
- **Compatibilidad:** El sistema es responsivo y funcional en moviles, tablets y las ultimas 2 versiones de navegadores modernos (Chrome, Firefox, Safari y Edge)

3.4 Herramientas utilizadas

revisar y agregar herramientas utilizadas

- **Herramientas tecnológicas:** Se utilizara **Postman** y **Swagger** para evaluar y documentar los endpoints RESTful del Backend, Para rendimiento se utilizará JMeter para inyección de carga, para simular los 200 usuarios requeridos. Para la seguridad, escáneres de vulnerabilidades web para validar la protección CSRF/XSS.
- **Recursos humanos:** Analista QA, ingenieros de seguridad para auditorías y un grupo representativo de 5 usuarios de la tercera edad para pruebas empíricas.
- **Recursos técnicos y de entorno:** Dispositivos móviles, tablets y computadores de escritorio con las versiones recientes de Chrome, Safari, Firefox y Edge. Se requerirá un entorno de pruebas con la misma arquitectura que la producción: Frontend (React/Material UI), Backend(Node.js/Express), y Base de datos (PostgreSQL).

4. Diseño de casos de prueba

ID	NOMBRE	REQUERIMIENTO
CP-01	Autenticación Exitosa	REQ-FUNC-1.1
DESCRIPCIÓN		
Validar que el sistema permita a un usuario iniciar sesión usando correo y contraseña.		

PRECONDICIONES
El usuario debe estar previamente registrado en el sistema.
PASOS
1. Ingresar a la pagina del login. 2. Ingresar correo y contraseña. 3. Hacer click en iniciar sesión.
RESULTADO ESPERADO
El login se efectúa correctamente y el servidor devuelve un token de sesión (JWT).
CRITERIO DE ACEPTACIÓN
El login exitoso genera un token de sesión (JWT) válido y otorga acceso al sistema.
DATOS DE PRUEBA
Correo: correo_medico_prueba@gmail.com **Contraseña:** Medico.Prueba123

ID	NOMBRE	REQUERIMIENTO
CP-02	Registro de examen médico	REQ-FUNC-3.1
DESCRIPCIÓN		
Comprobar que el usuario de tipo “Médico” pueda registrar un nuevo examen a un paciente.		
PRECONDICIONES		

Estar autenticado en el sistema como Médico y debe existir un paciente creado previamente.
PASOS
1. Acceder al dashboard de pacientes 2. Seleccionar un paciente 3. Ingresar información médica del nuevo examen 4. Guardar
RESULTADO ESPERADO
El sistema persiste la información en PostgreSQL y asocia el examen al paciente indicado.
CRITERIO DE ACEPTACIÓN
La operación CRUD funciona correctamente validando los campos y se registra la acción en el módulo de auditoria.
DATOS DE PRUEBA
Rut de paciente existente, Detalles clínicos ficticios del examen.

ID	NOMBRE	REQUERIMIENTO
CP-03	Carga de documentos	REQ-FUNC-4.4
DESCRIPCIÓN		
Asegurar que los documentos adjuntos (PDF, DOC, etc.) se guardan en el storage interno de forma segura.		
PRECONDICIONES		

Usuario médico con sesión iniciada(JWT vigente) editando o creando un registro médico.
PASOS
1. Seleccionar la opción de adjuntar documento. 2. Subir un archivo en formato PDF. 3. Guardar cambios en el examen médico.
RESULTADO ESPERADO
El archivo se transfiere via red utilizando TLS, se almacena en el servidor y su ruta queda referenciada en la base de datos.
CRITERIO DE ACEPTACIÓN
El tiempo de subida del documento no supera los 10 segundos.
DATOS DE PRUEBA
Archivo PDF de prueba tamaño regular (ej. 2MB)

ID	NOMBRE	REQUERIMIENTO
CP-04	Auditoría de acciones críticas	RF-5.1
DESCRIPCIÓN		
Validar que al eliminar un usuario o documento se genere un registro en el módulo de auditoría.		
PRECONDICIONES		

Estar autenticado como Administrador y tener un usuario de prueba creado en el sistema.
PASOS
1. Acceder al dashboard y dirigirse a la gestión de usuarios. 2. Seleccionar el usuario de prueba y eliminarlo. 3. Navegar a la página de auditoría y buscar el último registro.
RESULTADO ESPERADO
El sistema ejecuta la eliminación lógica y crea una nueva entrada en auditoría detallando que se eliminó y quien lo hizo.
CRITERIO DE ACEPTACIÓN
Se generan registros de auditoría en cada acción crítica sin excepciones.
DATOS DE PRUEBA
Credenciales de usuario Administrador y un registro de prueba

ID	NOMBRE	REQUERIMIENTO
CP-05	Accesibilidad para adultos mayores	RNF-USAB-1
DESCRIPCIÓN		
Comprobar que la interfaz cumple con los estándares mínimos de accesibilidad visual requeridos por el sistema.		
PRECONDICIONES		

Aplicación desplegada en entorno QA y visible desde un navegador moderno.
PASOS
1. Ingresar al dashboard principal. 2. Inspeccionar el código para verificar el tamaño de la fuente y el uso de etiquetas ARIA. 3. Navegar por los menús utilizando únicamente la tecla “TAB”.
RESULTADO ESPERADO
Todos los textos principales tienen un tamaño de al menos 12px, las etiquetas ARIA responden al foco del teclado y los controles de UI tienen el tamaño mínimo requerido.
CRITERIO DE ACEPTACIÓN
Las pruebas de usabilidad no muestran bloqueos mayores y aprueban el cumplimiento básico de accesibilidad.
DATOS DE PRUEBA
Navegador con herramientas de desarrollador activadas.